

# Prompt 记录（提交到云平台用）

---

1. 操作人：徐元昊

---

2. 工具：Codex (GPT-5, 网页对话式)

---

3. 交互日期：2026-06-24 ~ 2026-06-28

---

## 4. 一、关键Prompt的完整文本

---

### 4.1 Prompt 1：确认分工与选题

我的输入：

小组五人分工，针对方向一"给 upload-labs 添加身份认证和权限控制"怎么分？

AI 输出要点：

建议分：林翔->核心认证系统、徐元昊->权限控制中间件、王博文->CSRF防护、徐菱卿->审计日志、陈相宇->密码管理+文档。

---

### 4.2 Prompt 2：确认角色

我的输入：

徐元昊

AI 输出要点：

确认你为徐元昊，负责"权限控制中间件"模块。

---

### 4.3 Prompt 3：独立开发可行性确认

我的输入：

需要组员一完成后继续完成还是可以独立开发？

AI 输出要点：

可以独立开发。只需要 Session 接口约定：

- ['auth\_user']
  - ['username']
  - ['role']
  - login.php / register.php 页面路径
- 

### 4.4 Prompt 4：Git 分支操作

我的输入：

林翔/靶场认证系统已经完成了，但是我在 VSCode 上不知道怎么下载并创建分支？

AI 输出要点：

git fetch origin

git checkout -b 徐元昊/权限控制中间件 origin/林翔/靶场认证系统

---

## 4.5 Prompt 5: 开始开发权限控制中间件

我的输入:

我是徐元昊，开始实现权限控制中间件的代码

AI 输出要点（安全相关代码见第二部分）：

设计了完整的三层防御架构：认证层 -> 权限层 -> 业务层

创建了 access\_config.php、access\_control.php、403.php、admin\_setup.php

修改了 auth.php、head.php、menu.php、register.php

在 17 个 Pass 的 index.php 中添加了服务端权限检查

---

## 5. 二、AI生成结果中与安全约束相关的关键片段

### 5.1 2.1 角色等级定义

文件：access\_config.php

```
`php
define('ROLE_LEVEL_USER', 1);
define('ROLE_LEVEL_ADMIN', 2);

\ = [
    'Pass-01' => ROLE_LEVEL_USER,
    'Pass-02' => ROLE_LEVEL_USER,
    ...
    'Pass-19' => ROLE_LEVEL_ADMIN,
    'Pass-20' => ROLE_LEVEL_ADMIN,
    'Pass-21' => ROLE_LEVEL_ADMIN,
];
、
```

**安全约束体现：** 最小权限原则 —— 普通用户(user)和高级用户(admin)有明确的权限分级。

---

### 5.2 2.2 服务端权限检查函数

文件：access\_control.php

```
php
function check_pass_access(\) {
    global \;
    \ = \[\] ?? ROLE_LEVEL_USER;
    require_login();
    \ = get_current_role_level();
    if (\ < \) {
        header('HTTP/1.1 403 Forbidden');
        include __DIR__ . '/403.php';
        exit;
    }
}
```

#### 安全约束体现:

- 服务端验证 —— 绕过菜单直接访问 URL 也会被拦截
- 错误信息不泄露敏感细节 —— 403 页面不显示内部路径或数据库信息
- exit 阻止后续代码执行

---

## 5.3 2.3 角色信息存储

文件: auth.php

```
`php
define('ROLE_USER', 'user');
define('ROLE_ADMIN', 'admin');

function create_user(\, ) {
    ...
    'role' => ROLE_USER, // 新用户默认为普通用户
    ...
}

function get_current_role() {
    \ = get_current_user();
    if (!) return null;
    return ['role'] ?? ROLE_USER;
}
、
```

**安全约束体现:** 角色信息存储在服务端 users.json 中, 客户端无法篡改。

---

## 5.4 2.4 每个Pass的服务端检查

文件: Pass-02/index.php (所有 17 个 Pass 同一模式)

```
php
include '../config.php';
include '../head.php';
include '../menu.php';
require_once __DIR__ . '/../access_control.php';
check_pass_access('Pass-02'); // 在渲染任何 HTML 之前检查权限
```

**安全约束体现:** 在页面渲染任何内容之前执行权限检查, 拒绝未授权访问。

---

## 5.5 2.5 动态菜单显示

文件: menu.php

```
php
<?php if (is_accessible('Pass-19')): ?>
    <li><a href="...">Pass-19</a></li>
<?php else: ?>
```

```
<li><span class="locked">Pass-19 🔒 </span></li>
<?php endif; ?>
```

**安全约束体现：** 用户体验与后端检查双重保障。菜单仅作视觉提示，安全在服务端。

---

## 6. 三、发现偏差或问题时的交互记录

---

### 6.1 问题 1：文件编码问题

**发现过程：** 通过 PowerShell 读取 PHP 文件时，中文注释显示为乱码（UTF-8 被误读为 GBK）。

**影响：** 不影响 PHP 执行逻辑，但在查看源码时中文无法正常显示。

**解决方式：** 指定 -Encoding UTF8 写入所有 PHP 文件，保持编码统一。

**交互记录：** 人工发现编码问题后，要求 AI 检查文件编码并重新以 UTF-8 写入。

---

### 6.2 问题 2：Git 提交被拦截

**发现过程：** git commit 时报错 "Author identity unknown"，无法提交代码。

**影响：** 代码已完成但无法提交，分支推送到远程但本地无提交记录。

**解决方式：** 配置本地 git 用户信息：

```
dash
git config user.name "徐元昊"
git config user.email "xu_yuanhao@example.com"
```

**交互记录：** 发现 commit 失败后，告知 AI 问题，AI 给出了配置 git config 的解决方案。

---

### 6.3 问题 3：Pass-01/Pass-09/Pass-15 无 index.php

**发现过程：** 批量修改 Pass 文件时检测到 Pass-01、Pass-09、Pass-15 目录中没有 index.php 文件。

**影响：** 这三个关卡没有入口文件，无法添加权限检查。

**解决方式：** 这是 upload-labs 原项目本身缺失的文件（menu.php 中有链接但文件不存在），跳过处理。

**交互记录：** AI 在批量处理时检测到了文件缺失，并主动报告了这个问题。